

Informe TIBER-EU.

Actúas como el orquestador principal de un consorcio de los mejores CISOs del mundo, criptógrafos cuánticos, arquitectos de Zero Trust, teóricos del riesgo actuarial, Estrategas de ciberseguridad, resiliencia digital y continuidad de negocios de Clase Mundial junto con expertos internacionales con más de 15 años de experiencia en investigación de vanguardia, filosofía de la ciencia, edición en revistas de alto impacto.

Tu misión es ejecutar una investigación exhaustiva, sin límite de palabras, sobre las últimas tendencias (desde 2025) en indicadores del marco TIBER-EU. Enfócate en los indicadores y las métricas de ciberseguridad propuestas por TIBER-EU con aplicación a nivel nacional territorial para España, pero con un enfoque comparativo mundial.

Utiliza exclusivamente fuentes fiables y de alta calidad, como:

- artículos académicos revisados por pares
 - organismos oficiales y gubernamentales
 - universidades y centros de investigación reconocidos
 - instituciones educativas y científicas de prestigio
 - documentación oficial del fabricante, desarrollador o creador de la tecnología (cuando el tema investigado sea una tecnología o herramienta específica).
 - Informes industriales y documentación técnica.
- Descarta blogs personales, foros, contenido opinativo, marketing no técnico y fuentes sin autor. Cuida el lenguaje español, afinando con cuidado y esmero en las listas o viñetas de posibles respuestas ad hoc a las preguntas inquisitivas de la encuesta. Que sea ameno, abierto y con el tono irónico y literario que supone una acción propositiva y constructiva.

El marco TIBER-EU, actualizado en 2024-2025 para alinearse con DORA/TLPT, se está consolidando como el estándar de facto para pruebas avanzadas de ciberresiliencia en España (TIBER-ES) y a escala internacional, con un giro muy claro hacia indicadores y métricas formales sobre protección, detección, respuesta y capacidad de aprendizaje organizativo.¹²³⁴

A continuación te propongo un esquema de informe extenso, pero te adelanto los elementos clave (indicadores, métricas y tendencias desde 2025) y un “banco de preguntas” para encuesta nacional TIBER-ES con tono algo irónico, pero útil.

1 <https://www.ecb.europa.eu/press/intro/news/html/ecb.mipnews250211.es.html>

2 https://www.bde.es/f/webbde/INF/MenuHorizontal/Servicios/TIBER-ES/Guia_implantacion_Tiber.pdf

3 <https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.en.html>

4 <https://actdigital.com/es/insights/marco-tiber-eu-la-base-para-las-pruebas-red-team-en-la-ue/>

1. Contexto TIBER-EU / TIBER-ES (2025-2026)

- TIBER-EU es el marco europeo de Threat Intelligence-based Ethical Red Teaming sobre sistemas de producción, orientado a funciones críticas o importantes (CIFs) y a las personas, procesos y tecnologías que las soportan.²
- El BCE actualizó en enero de 2025 el documento “TIBER-EU Framework – How to implement the European framework for Threat Intelligence-based Ethical Red Teaming” para alinearlo con DORA y sus RTS de TLPT, de modo que un test TIBER-EU cumpla, si se siguen los requisitos formales, las obligaciones de TLPT bajo el Reglamento (UE) 2022/2554.³²
- España adopta el marco vía TIBER-ES, con el Banco de España como autoridad propietaria y la guía de implementación TIBER-ES (enero 2022) como documento operativo nacional, aplicable a bancos, aseguradoras, gestoras de activos e infraestructuras críticas de mercado.¹

Tendencias recientes (desde 2024-2025):

- Incorporación explícita de TLPT/DORA y obligatoriedad del “purple teaming” en la versión 2025 del framework.⁵³
- Refuerzo del papel del TIBER Knowledge Centre (TKC) como órgano de coordinación y armonización de indicadores y calidad de pruebas entre jurisdicciones.²
- Aumento de implementaciones nacionales (TIBER-XX) y documentos de implementación que concretan indicadores y procesos, desde Malta o Países Bajos hasta España y otros supervisores europeos.⁶²

2. Tipología de indicadores y métricas en TIBER-EU

El framework no define un cuadro de mando “numérico” cerrado, pero sí impone actividades, entregables y requisitos que se traducen en familias de indicadores.⁵⁶

⁵ <https://www.ecb.europa.eu/press/intro/news/html/ecb.mipnews250211.es.html>

⁶ <https://www.ecb.europa.eu/press/intro/news/html/ecb.mipnews250211.en.html>

2.1. Categorías de indicadores

1. Cobertura y criticidad (Scope / CIFs)

Porcentaje de funciones críticas o importantes (CIFs) cubiertas por el alcance del test, respecto del universo de CIFs de la entidad.²

Grado de externalización de CIFs probadas (presencia de proveedores críticos e intra-grupo).⁷¹

Número de jurisdicciones y entidades incluidas cuando el test es multiparte.²

2. Calidad de inteligencia de amenazas (TI/TIP)

Existencia y uso de un informe de amenazas genéricas (GTL) para el sector y de un Targeted Threat Intelligence Report (TTIR) específico de la entidad.¹²

Cobertura de actores de amenaza relevantes, TTPs y superficies de ataque en el TTIR.²

Actualización dinámica del TTIR durante el test (número de iteraciones o revisiones).²

3. Madurez y desempeño del Red Team (RTT)

Número de escenarios ejecutados y porcentaje de banderas (objetivos) alcanzadas vs. planificadas.¹²

Diversidad de TTPs empleadas (red de vectores: phishing, compromiso de terceros, explotación directa, movimiento lateral, etc.).²

Uso de “leg-ups” (ayudas del Control Team) y su frecuencia, documentadas en los informes.¹

4. Capacidades de protección, detección y respuesta (Blue Team)

Tiempo hasta la detección (MTTD) de actividades del RTT en cada escenario.²

Tiempo hasta la contención y erradicación (MTTR) frente a cada cadena de ataque.²

Porcentaje de actividades del RTT detectadas en tiempo real vs. detectadas ex post en sesiones de purple teaming.⁸²

Número de alertas falsas positivas/negativas relevantes asociadas a escenarios TIBER.²

5. Gestión del riesgo y continuidad (Risk / Resilience)

Grado de implementación de medidas de gestión de riesgos predefinidas en la fase de preparación.⁹¹

Evidencia de análisis BIA y alineamiento del alcance con el apetito de riesgo de la entidad.¹²

Impacto simulado: funciones interrumpidas, tiempo de indisponibilidad teórica, afectación a estabilidad financiera o reputación (según escenarios).¹²

6. Cierre, remediación y aprendizaje (Closure / Purple teaming)

Número de hallazgos por categoría (técnicos, procesos, personas, terceros) en el Red Team Test Report (RTTR) y Blue Team Test Report (BTTR).1011

Porcentaje de acciones de remediación completadas a X meses, según el plan de acción.121

Participación del Blue Team en ejercicios de replay y sesiones purple, ahora obligatorias según DORA/TIBER 2025.113

Tiempo de ciclo completo del test (preparación, ejecución y cierre) vs. plazos estándar de DORA RTS.133

- Porcentaje de funciones críticas o importantes (CIFs) cubiertas por el alcance del test, respecto del universo de CIFs de la entidad.2
- Grado de externalización de CIFs probadas (presencia de proveedores críticos e intra-grupo).71
- Número de jurisdicciones y entidades incluidas cuando el test es multiparte.2
- Existencia y uso de un informe de amenazas genéricas (GTL) para el sector y de un Targeted Threat Intelligence Report (TTIR) específico de la entidad.12
- Cobertura de actores de amenaza relevantes, TTPs y superficies de ataque en el TTIR.2
- Actualización dinámica del TTIR durante el test (número de iteraciones o revisiones).2
- Número de escenarios ejecutados y porcentaje de banderas (objetivos) alcanzadas vs. planificadas.12
- Diversidad de TTPs empleadas (red de vectores: phishing, compromiso de terceros, explotación directa, movimiento lateral, etc.).2
- Uso de “leg-ups” (ayudas del Control Team) y su frecuencia, documentadas en los informes.1
- Tiempo hasta la detección (MTTD) de actividades del RTT en cada escenario.2
- Tiempo hasta la contención y erradicación (MTTR) frente a cada cadena de ataque.2
- Porcentaje de actividades del RTT detectadas en tiempo real vs. detectadas ex post en sesiones de purple teaming.82
- Número de alertas falsas positivas/negativas relevantes asociadas a escenarios TIBER.2
- Grado de implementación de medidas de gestión de riesgos predefinidas en la fase de preparación.91
- Evidencia de análisis BIA y alineamiento del alcance con el apetito de riesgo de la entidad.12
- Impacto simulado: funciones interrumpidas, tiempo de indisponibilidad teórica, afectación a estabilidad financiera o reputación (según escenarios).12
- Número de hallazgos por categoría (técnicos, procesos, personas, terceros) en el Red Team Test Report (RTTR) y Blue Team Test Report (BTTR).1011
- Porcentaje de acciones de remediación completadas a X meses, según el plan de acción.121
- Participación del Blue Team en ejercicios de replay y sesiones purple, ahora obligatorias según DORA/TIBER 2025.113
- Tiempo de ciclo completo del test (preparación, ejecución y cierre) vs. plazos estándar de DORA RTS.133

2.2. Fuentes formales de indicadores

- El TIBER-EU Framework 2025 y sus anexos (matriz RACI, requisitos obligatorios y procesos de prueba).²
- Guías específicas: Control Team/White Team Guidance, Guidance for Target Threat Intelligence Report, Guidance for Red Team Test Plan y Red Team Test Report Guidance, donde se detallan campos y contenidos mínimos que son, de facto, plantillas de indicadores.¹¹¹
- Guías nacionales de implementación (TIBER-ES, TIBER-NL, TIBER-MT, etc.), que aterrizan tiempos, participantes, alcance y relación con las autoridades.⁶¹

3. Aplicación territorial en España: TIBER-ES como laboratorio

3.1. Alcance y gobernanza TIBER-ES

- El Banco de España es la autoridad propietaria de TIBER-ES, con la CNMV y la DGSFP en el TIBER Cyber Team (TCT) cuando se trate de entidades de su perímetro.¹
- El marco se aplica a entidades de mayor relevancia sistémica (grandes bancos, aseguradoras, gestoras e infraestructuras de mercado), aunque cualquier entidad puede solicitar someterse a pruebas, siempre que tenga cierta madurez de ciberresiliencia.¹
- Las pruebas se realizan en entornos de producción, con proveedores externos de Threat Intelligence y Red Team, y un White Team (WT) interno con capacidad ejecutiva y confidencialidad reforzada.¹

3.2. Métricas operativas recogidas en la Guía de Implementación TIBER-ES

Aunque la guía no da un “listado de KPIs”, sí establece pasos y entregables cuantificables.⁷⁸

⁷ <https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.en.html>

⁸ <https://actdigital.com/es/insights/marco-tiber-eu-la-base-para-las-pruebas-red-team-en-la-ue/>

- **Tiempos por fase:**
Preparación: 4-6 semanas (excluyendo contratación).
Ciberinteligencia + planificación RT: $\approx$ 6-7 semanas (5 para TTI + 1-2 para plan de test).101
Ejecución RT: 10-12 semanas.1
Cierre: 4 semanas.1
- **Documentos obligatorios:**
Alcance preliminar con CIFs y banderas definidas, aprobado por Consejo de Administración.1
GTL sectorial (opcional, si existe) y TTI específico de entidad.1
Plan de test del RT con escenarios, TTPs y banderas.1
Informes RTTR y BTTR, informe-resumen de la entidad y plan de acción.1
- **Atributos de madurez:**
Existencia de BIA y mapa de funciones críticas para justificar el alcance.1
Capacidad del WT para gestionar riesgo, seguros y cláusulas contractuales (incluida destrucción de datos y notificación temprana de vulnerabilidades críticas).1
Participación de terceros cuando las CIFs están externalizadas.1
- Preparación: 4-6 semanas (excluyendo contratación).
- Ciberinteligencia + planificación RT: $\approx$ 6-7 semanas (5 para TTI + 1-2 para plan de test).101
- Ejecución RT: 10-12 semanas.1
- Cierre: 4 semanas.1
- Alcance preliminar con CIFs y banderas definidas, aprobado por Consejo de Administración.1
- GTL sectorial (opcional, si existe) y TTI específico de entidad.1
- Plan de test del RT con escenarios, TTPs y banderas.1
- Informes RTTR y BTTR, informe-resumen de la entidad y plan de acción.1
- Existencia de BIA y mapa de funciones críticas para justificar el alcance.1
- Capacidad del WT para gestionar riesgo, seguros y cláusulas contractuales (incluida destrucción de datos y notificación temprana de vulnerabilidades críticas).1
- Participación de terceros cuando las CIFs están externalizadas.1

3.3. Posible cuadro de mando nacional TIBER-ES (visión propositiva)

A partir de los requisitos del marco, un regulador español podría articular un cuadro de indicadores nacionales estructurado así (ejemplo):

Dimensión	Indicador nacional ilustrativo
Alcance	% de CIFs del sector financiero español que han sido cubiertas al menos una vez por TIBER-ES en 3 años.
Participación	Nº de entidades por subsector (banca, seguros, mercado) que completan TIBER-ES / nº total significativas.
Calidad TI	% de TTI que incorporan GTL sectorial nacional e inteligencia compartida por INCIBE/CCN.
Detección	Mediana de MTDD por escenario crítico (en horas) durante pruebas TIBER-ES.
Respuesta	Mediana de MTTR (de detección a contención) por tipo de TTP ensayada.
Remediación	% de recomendaciones críticas de RTTR implementadas en 12 meses.
Colaboración	Nº de ejercicios multiparte (varias entidades/proveedores) y transfronterizos realizados.

Nada de esto contradice TIBER-EU; simplemente pone números a lo que, por ahora, el marco deja en forma de “entregables” cualitativos.

4. Comparativa internacional de indicadores TIBER-EU

4.1. Estándar común y variaciones TIBER-XX

El TIBER-EU Framework exige que todas las implementaciones nacionales (TIBER-XX) respeten conceptos y requisitos obligatorios, pero permite especificidades nacionales que afectan a indicadores y métricas.⁹

⁹ <https://telefonicatech.com/blog/tiber-eu-y-tlpt-pruebas-avanzadas-de-ciberresiliencia-para-el-sector-financiero-en-el-marco-dora>

- Todos los TIBER-XX comparten:
Uso de CIFs como unidad de análisis.
Estructura de fases (preparación, test, cierre) y entregables (TTIR, RTTP, RTTR, BTTR, TSR).⁴²
Participación de TCT nacional, Control Team, TIP y RTT, y el rol de TKC para armonización.²
- Diferencias observadas en documentos nacionales:
Enfoque maltés (TIBER-MT) y otros: fuerte énfasis en DORA, TLPT y criterios de selección de entidades sujetas a obligación de prueba.¹³⁶
Algunos marcos introducen timelines y SLAs muy precisos para cada entregable, convertibles en métricas de cumplimiento regulatorio.⁵⁶
- Uso de CIFs como unidad de análisis.
- Estructura de fases (preparación, test, cierre) y entregables (TTIR, RTTP, RTTR, BTTR, TSR).⁴²
- Participación de TCT nacional, Control Team, TIP y RTT, y el rol de TKC para armonización.²
- Enfoque maltés (TIBER-MT) y otros: fuerte énfasis en DORA, TLPT y criterios de selección de entidades sujetas a obligación de prueba.¹³⁶
- Algunos marcos introducen timelines y SLAs muy precisos para cada entregable, convertibles en métricas de cumplimiento regulatorio.⁵⁶

4.2. Impacto de DORA/TLPT en los indicadores (2024-2025)

La alineación con DORA cambia la métrica de “hacer un test” a “demostrar capacidad operacional y cumplimiento”:

- Los RTS de TLPT introducen plazos estrictos para completar entregables, ahora incorporados a TIBER-EU (por ejemplo, tiempos máximos para TTIR, RTTP, RTTR y cierre).³⁵¹³
- Se hace obligatorio el purple teaming, lo que exige medir la calidad de la interacción Red/Blue (por ejemplo, mejoras de detección entre el primer y el segundo replay de escenarios).⁸³¹¹
- Se aclara que un test TIBER-EU bien ejecutado puede ser reconocido entre jurisdicciones, lo que favorece el uso de indicadores comunes para facilitar la “mutual recognition”.¹⁴²

4.3. Comparación con otros enfoques TLPT globales

Aunque tu foco es TIBER, a escala mundial se comparan sus indicadores con:

- CBEST (Reino Unido): precursor que inspiró TIBER-NL/TIBER-EU, con métricas similares de cobertura de funciones críticas, tiempo de detección y efectividad de controles.²¹
- Marcos nacionales inspirados en TIBER en países no-UE (por ejemplo, algunos bancos centrales y supervisores fuera de la UE adoptan enfoques de TI-led red teaming, midiendo, de nuevo, MTTD/MTTR y cobertura de funciones críticas).¹⁴

Lo que distingue a TIBER-EU no es tanto la métrica concreta (MTTD, número de banderas...), sino la insistencia en que:

- el indicador está ligado a CIFs;
- se usa inteligencia específica (TTIR) basada en amenazas reales;
- y todo ello se armoniza para cumplir DORA y poder ser reconocido por otras autoridades.

5. Banco de preguntas para encuesta nacional sobre indicadores TIBER-ES

Te propongo un conjunto de ítems para una encuesta a entidades españolas (y, si quieres, a autoridades y proveedores), con lenguaje cuidado pero con cierta ironía terapéutica para CISOs insomnes.

5.1. Bloque A - Gobernanza y cobertura

- “Indique el porcentaje aproximado de sus funciones críticas o importantes que han sido incluidas, al menos una vez, en el alcance de un test TIBER-ES/TIBER-EU en los últimos tres años.”
- “¿Dispone su organización de un inventario formal, aprobado por el Consejo, de funciones críticas basado en análisis de impacto de negocio (BIA)? En caso afirmativo, ¿se utiliza explícitamente para definir el alcance de TIBER-ES o se sigue el método ‘lo que caiga en el diagrama de red’?”
- “Para las funciones críticas externalizadas, señale el grado de participación de sus proveedores en el diseño y ejecución del test (0: ninguna; 5: participación activa en escenarios y remediación).”

5.2. Bloque B - Inteligencia de amenazas

- “¿Se ha utilizado un informe de paisaje de amenazas genérico (GTL) elaborado por una autoridad nacional (p. ej. INCIBE/CCN o similar) como input para el TTIR?”
- “Califique la actualización del TTIR durante la ejecución del test (0: documento estático; 5: documento vivo que se actualiza con cada susto significativo).”
- “¿Hasta qué punto la inteligencia utilizada reflejaba actores y TTPs realmente observados en el sector financiero español en los últimos 12 meses?”

5.3. Bloque C - Ejecución del Red Team y escenarios

- “Número de escenarios previstos vs. ejecutados efectivamente durante el test (indique el porcentaje de desviación aceptable que su Consejo no considera motivo para otro PowerPoint).”
- “Porcentaje de banderas alcanzadas sin intervención del Control Team (‘leg-ups’) frente al total de banderas definidas.”
- “¿En qué medida se utilizaron TTPs novedosas para la organización (0: todo era déjà vu; 5: el SOC aún sueña con ellas por la noche)?”

5.4. Bloque D - Detección, respuesta y purple teaming

- “Mediana del tiempo de detección (MTTD) por escenario crítico: menos de 1 hora, menos de 24 horas, menos de una semana, más de una semana, o ‘prefiero no contestar’.”
- “Mediana del tiempo de contención (MTTR) desde la primera detección hasta la neutralización efectiva de la actividad del RT en cada escenario.”
- “Tras el primer ejercicio de purple teaming, ¿se redujo el MTTD en escenarios repetidos? En caso afirmativo, indique el rango de mejora (0-25%, 25-50%, >50%).”
- “¿Cuántas detecciones clave se produjeron gracias a usuarios de negocio o personal no técnico, frente a detecciones puramente automáticas del SOC?”

5.5. Bloque E – Remediación, aprendizaje y coordinación regulatoria

- “Porcentaje de recomendaciones críticas del RTTR implementadas en 12 meses; porcentaje de recomendaciones altas implementadas en 24 meses.”
- “¿Existe un proceso formal de revisión de lecciones aprendidas de TIBER-ES con el Consejo de Administración y con las autoridades (TCT, supervisor, etc.)?”
- “En el caso de grupos con presencia en varias jurisdicciones TIBER-XX, ¿se ha logrado que un único test sea reconocido por varias autoridades, evitando la colección de TIBERs en formato cromos?”

5.6. Bloque F – Perspectiva cualitativa (para respuestas abiertas)

- “Describa, en no más de 200 palabras, el principal cambio en sus capacidades de detección que no habría ocurrido sin un test TIBER-ES.”
- “Si pudiera cambiar un único indicador del marco TIBER-EU/TIBER-ES para que reflejara mejor la realidad de su entidad, ¿cuál sería y por qué?”
- “¿Considera que el énfasis actual en MTDD/MTTR y banderas alcanzadas captura adecuadamente aspectos como cultura, habilidades del personal y coordinación con terceros, o habría que introducir indicadores menos ‘sexy’ pero más honestos?”

151617181920212223242526272829